

**TIB SYSTEMS**

*SAP SOX / ITGC Controls Career Guide*

# Controls Consultant Study Guide (FvCL)

*From the Story to the Screen*

The Access List, in full — plus your working relationships, your first 90 days, and a clear path into the SAP Testing Execution Guide online course.

---

TIB-TRN-STUDYGUIDE-JUNIOR-001

Version 1.0

Built from the TIB Onboarding Readiness Manual — Junior Edition

Atlanta · Hyderabad · Ras Al Khaimah

# Contents

## Contents

|                                                                     |    |
|---------------------------------------------------------------------|----|
| Contents.....                                                       | 2  |
| How to Use This Study Guide.....                                    | 4  |
| The Order, and Why It's This Order.....                             | 4  |
| Part 1 — The Access List.....                                       | 5  |
| Thornfield Industrial Group, Inc. ....                              | 6  |
| The People of This Story.....                                       | 6  |
| Part 2 — Team Job Descriptions & Working Relationships .....        | 30 |
| Quick-Reference: Relationship Matrix .....                          | 30 |
| <i>Your Senior SAP SOX/ITGC Controls Lead</i> .....                 | 30 |
| <i>Fellow Junior Consultants</i> .....                              | 31 |
| <i>SAP Basis Team</i> .....                                         | 32 |
| <i>SAP Security / GRC Access Control Team</i> .....                 | 33 |
| <i>Business Process Owners (BPOs)</i> .....                         | 33 |
| Putting It All Together .....                                       | 34 |
| Part 3 — A Day in the Life .....                                    | 35 |
| A Representative Day, Hour by Hour .....                            | 35 |
| Five Testing Day-Types You'll Rotate Through.....                   | 36 |
| 1. <i>The Population-Pull Day</i> .....                             | 36 |
| 2. <i>The Sample-Testing Day</i> .....                              | 36 |
| 3. <i>The Evidence-Chase Day</i> .....                              | 36 |
| 4. <i>The Rework Day</i> .....                                      | 36 |
| 5. <i>The Escalation Day</i> .....                                  | 36 |
| Part 4 — The First 30 Days .....                                    | 37 |
| Week 1: System Access and Orientation.....                          | 37 |
| Week 2: Your First Supervised Test .....                            | 37 |
| Week 3: Building Independence on One Test Type .....                | 38 |
| Week 4: Your First Independent Assignment.....                      | 38 |
| This Looks Different Depending on Where You're Starting.....        | 39 |
| 30-Day Checklist .....                                              | 39 |
| Common First-Month Pitfalls to Avoid.....                           | 39 |
| Part 5 — The First 90 Days .....                                    | 40 |
| Days 31–60: Owning a Full Cycle, Cross-Training a Second Area ..... | 40 |

|                                                                  |    |
|------------------------------------------------------------------|----|
| Days 61–90: Judgment and Range .....                             | 40 |
| Your Growing Capability, With the Toolkit Underneath It .....    | 41 |
| Stakeholder Interface Cadence .....                              | 41 |
| 90-Day Milestones Checklist .....                                | 42 |
| Part 6 — The Workpaper & Evidence Reliability .....              | 43 |
| The Standard Workpaper, Field by Field .....                     | 43 |
| Is the Evidence Actually Reliable? .....                         | 44 |
| A Note on SAP Examples in This Guide and the Online Course ..... | 44 |
| Part 7 — The SAP Testing Execution Guide Online Course .....     | 46 |
| What the Course Covers .....                                     | 46 |
| How to Use It — Two Windows, Not One .....                       | 46 |
| Part 8 — Continuing Your Reading .....                           | 48 |
| How the Series Fits Together .....                               | 48 |
| Deficiency Coverage — Your Reading Map .....                     | 48 |
| The Recurring Cast, at a Glance .....                            | 50 |
| How You’ll Be Assessed .....                                     | 51 |
| How the Weight Breaks Down .....                                 | 51 |

## How to Use This Study Guide

### *Read this before anything else*

This guide exists to close a specific gap: the SAP Testing Execution Guide online course teaches you exactly which screen to open and which button to press for all 40 control scope areas — but it doesn't teach you why any of it matters, who you're doing it for, or what your first ninety days actually feel like. Read on its own, the online course is a list of transactions with no story behind them.

This guide is that story, plus the working knowledge that sits around it. It's built directly from TIB Systems' own Junior Consultant Onboarding Readiness Manual, restructured into the order a new hire should actually absorb it in — ending with a clear handoff into the online course itself.

### The Order, and Why It's This Order

This sequence isn't arbitrary — it follows the exact recommended reading order from TIB's own onboarding manual, with one addition: a part on the workpaper and evidence reliability, inserted right where a junior consultant most needs it — after you understand the job, before you touch the system.

1. The Access List — a full story, not a summary, and not one you just read passively. Stop-and-decide exercises are built into it — the story pauses at the same moments a real consultant would have to make a call, and asks you to make it first.
2. Team Job Descriptions & Working Relationships — the same roles you just watched Nadia, Priya, Marcus, and Théo work with, written out as real relationships, escalation paths, and friction points.
3. A Day in the Life — the hour-by-hour rhythm behind the story you just read.
4. The First 30 Days and The First 90 Days — the week-by-week, cycle-by-cycle version of everything Nadia had to learn by living it.
5. The Workpaper & Evidence Reliability — what you actually have to produce, and the questions that determine whether an SAP report is good enough to rely on before you ever open the online course.
6. The SAP Testing Execution Guide Online Course — now that you know the world, the people, the rhythm, and what a defensible workpaper requires, the T-codes and Fiori navigation will actually mean something when you run them yourself.
7. Continuing Your Reading — a map for the other 21 stories in the series, to read progressively as your own testing assignments require, not all at once.

#### **THIS GUIDE IS NOT THE WHOLE LIBRARY**

The Access List is the only full story reproduced here — TIB's onboarding manual is explicit that this one story is essential reading before anything else makes sense. The remaining 21 stories stay in the TIB Story Library, to be read as your actual testing assignments call for them. Part 8 of this guide gives you the map for that.

## Part 1 — The Access List

---

### *A Controls Team Story — From Day One to Certification*

This is the full story, reproduced exactly as it appears in TIB’s Story Library. Read it start to finish before moving on — every other part of this guide, and the online course that follows it, assumes you already know Nadia, Priya, Marcus, Théo, and the access-list finding that opens the whole series.

#### A TIB SYSTEMS CONTROLS STORY

# THE ACCESS LIST

### *A Controls Team Story — From Day One to Certification*

*a novella*

*This is a work of fiction. Thornfield Industrial Group, its people, and its events exist only within these pages.*

## Thornfield Industrial Group, Inc.

*Thornfield Industrial Group manufactures and distributes precision components for heavy equipment, from a headquarters in Ashfield, Ohio and three plants across the Midwest. Fourteen months ago, Thornfield went public. This is its first year as a company that must certify — under its own CFO's signature — that its internal controls over financial reporting actually work.*

*Thornfield runs SAP S/4HANA across finance, procurement, and operations, with SAP GRC Access Control governing who can do what inside it. Somewhere in that system, on the day this story begins, sits an access combination nobody has looked at closely in five years.*

## The People of This Story

**Nadia Brooks** — Senior SAP SOX/ITGC Controls Lead. New to Thornfield. Not new to the work.

**Priya Nair** — Junior Controls Consultant. Sharp, fast, still learning when fast is a liability.

**Marcus Webb** — Junior Controls Consultant. Methodical to a fault. The one who never misses a footnote.

**Théo Laurent** — Junior Controls Consultant. Eager to please. Learning the hard way that a promise made to be kind can become a promise broken.

**Grace Odum** — Compliance Director. Nadia's manager. Carries the program's risk on her own shoulders, mostly quietly.

**Ray Sutton** — Program Manager. Owns the calendar. Loves a green status cell more than almost anything.

**Ilse Tan** — SAP Basis Lead. Keeps the system standing. Answers to a different chain than Nadia's.

**Devon Okoye** — SAP Security & GRC Access Control Analyst. Built the access model years ago. About to have to rebuild part of it.

**Roberto Salinas** — Director of Accounts Payable. Runs a tight, loyal team. Doesn't love being told his process has a gap.

**Yusuf Bello** — Internal Audit Manager. Independent by design. Will not be rushed.

**Claire Whitmore** — Senior Manager, Kestrel & Marsh LLP (External Auditors). Precise, unhurried, and not on Thornfield's payroll.

**Diane Whitfield** — Chief Financial Officer. Signs the certification. Everything in this story eventually reaches her desk, in summary form.

## CHAPTER 1

**Day One**

Nadia Brooks arrived at Thornfield Industrial Group forty minutes before her start time, which turned out to be both too early and exactly right — too early for anyone to have made her a badge, exactly right to watch the building wake up before it had to perform for her.

The lobby smelled like fresh carpet glue and burnt coffee. A television bolted to the wall looped Thornfield's stock ticker, four months old and still climbing in a lazy, hopeful line — THFD, up two cents, up two cents, up two cents, as if the number itself were nervous about the attention. Fourteen months ago this company had not existed on any exchange. Now it existed on all of them, and somewhere in a filing cabinet or a shared drive was a signature page that said the CFO believed the controls behind these numbers actually worked.

Nadia's job, as of nine o'clock this morning, was to help make that true.

Grace Odum met her at the elevator bank with the particular briskness of someone who has forty minutes and eleven things to fit inside it. Compliance Director, the email signature had said. In person she looked like someone who had learned to walk fast without ever seeming to hurry.

"You're early," Grace said, in a tone that made it a compliment. "Good. We're behind, so I'll take early."

"Behind on what, specifically?" Nadia asked, because specific was the only way she knew how to start anything.

Grace almost smiled. "Everything, specifically. This is our first SOX cycle as a public company, Nadia. We don't have a prior year to lean on. We don't have a rhythm yet. What we have is a CFO who has to sign a certification in nine months saying our controls work, an audit committee that will ask hard questions if she's wrong, and three junior consultants who have never worked a live SAP environment under this kind of pressure before." She pressed the elevator button a second time, as if that helped. "And you."

The elevator doors opened onto the fourth floor, where a glass-walled room had been claimed, somewhat apologetically, with a paper sign that read CONTROLS TEAM taped at a slight angle to the door.

Inside, three people looked up. A woman with a laptop open to three windows at once, mid-sentence to no one. A man carefully squaring a stack of printed workpapers that did not need squaring. A third, younger, already on his feet with his hand out before Nadia had crossed the threshold.

"You must be Nadia. I'm Théo — Théo Laurent — it's really good to meet you, we've been, honestly, we've been a little worried you'd get here and think this whole thing is a mess." He said it fast, and a little too honestly, the way people do when the truth arrives before the filter catches up.

"It's fine to be a mess on day one," Nadia said. "It's not fine to still be a mess on day ninety. Let's make sure it's the first one, not the second."

The woman with three windows open closed one of them and stood. "Priya Nair. I've already started pulling the prior control documentation — well, there isn't really prior documentation, there's a consultant's binder from the pre-IPO readiness assessment, but it's — " she paused, recalibrating. "It's a starting point."

"Marcus Webb," said the man with the squared stack, not standing, but looking up with the calm of someone who has decided that panic is inefficient. "I've got the testing tracker built. It's got more red in it than I'd like, but at least it's honest red."

Nadia looked around the glass room — the paper sign on the door, the three laptops, the stack of workpapers that didn't need squaring but had been squared anyway because squaring things felt like doing something — and felt the particular, quiet satisfaction of a person who has found exactly the kind of problem she is good at solving.

"Okay," she said, setting her bag down on the one empty chair. "Tell me what's actually red."

## CHAPTER 2

**The Kickoff**

The kickoff meeting happened at ten, in a conference room with a screen that took four minutes and two dongles to find the right input, which everyone treated as a normal and expected part of any Thornfield meeting.

Ray Sutton ran it standing, tracker projected behind him, a program manager's particular energy radiating off him like heat off asphalt. "Eight testing cycles between now and year-end," he said, tapping the screen with a laser pointer he clearly enjoyed owning. "ITGC access reviews, change management, computer operations, plus the key financial controls in O2C, P2P, and R2R. Internal Audit signs off on scope by end of month. External audit — Kestrel and Marsh — starts interim testing in ten weeks. That is not a lot of runway, people."

Nadia watched him work the room and understood, within the first five minutes, what Ray Sutton actually cared about: the tracker turning green. Not a bad thing to care about. Not the only thing that mattered, either. She filed the distinction away for later, the way you file away the load-bearing wall in a house you've just moved into — you don't need it yet, but you will.

"Questions on scope before we move to workstream owners?" Ray asked.

"One," Nadia said. "Has anyone validated the SAP GRC Access Control rule set against the current org structure? We had three business units combine under one instance eighteen months ago. If the SoD rules weren't updated when that happened, we could be sitting on conflicts nobody's looked at."

A brief silence — the kind that tells you a question has landed somewhere real.

"That's a Devon question," Ray said, making a note. "Security lead. I'll get you two in a room this week."

Grace, at the end of the table, did not say anything, but Nadia caught the small, approving tilt of her head, the kind a manager gives when a new hire has just, on day one, asked the question that actually mattered.

• • •

Back in the glass room that afternoon, Nadia laid out the shape of the work on the whiteboard: three columns — ITGC, Key Controls, Deficiency Management — and beneath each, the cycle they'd be running for the next nine months.

"Priya, you're strongest on access and change management — I want you owning the GRC Access Control testing, starting with a fresh SoD conflict report once Devon's confirmed the rule set is current. Marcus, you've got computer operations and the batch job controls — Ilse in Basis is your primary contact, and I want every evidence request logged, not just emailed, so we have a trail. Théo — " she paused, choosing the words with some care, "you've got P2P and R2R

walkthroughs. You'll be spending real time with the business process owners. That's a relationship job as much as a testing job."

Théo nodded, already reaching for a notepad, already, Nadia suspected, planning to be liked by every business process owner he met. She made a private note to watch that particular instinct. It would serve him well right up until the moment it didn't.

## CHAPTER 3

## Walking the Floor

Roberto Salinas ran Accounts Payable the way some men run a kitchen — loudly, warmly, and with absolute certainty that nothing was wrong that couldn't be fixed by someone simply working a little harder.

"Nadia, right? Grace's new lead." He shook her hand like he meant it. "Théo said you wanted to walk the floor before we schedule the formal thing. Come on. I'll show you how the sausage actually gets made, not how it looks on the flowchart."

The AP floor was a long room of cubicles under fluorescent light, printers humming, a radio playing low from somewhere near the back. Roberto walked Nadia through it with the pride of a man showing off something he'd built. "Invoice comes in, gets matched against the PO and the receipt — three-way match, you know the drill — goes into the payment run on Thursdays. Denise handles vendor setup and payment runs both, has for five years now, never had an issue."

Nadia's attention caught on that sentence the way a splinter catches on a sweater — small, but not nothing. "Denise sets up the vendors and executes the payment runs? Same person, both steps?"

"Same person, five years, zero issues," Roberto said again, in the specific tone of a man repeating a fact he has said enough times that it has started to feel like an argument, rather than an answer. "She's the best we've got. Knows every vendor in that system by heart."

"I believe that," Nadia said, and meant it. "I'm not questioning Denise. I'm asking about the access design around her."

Roberto's smile didn't move, exactly, but something behind it did. "You SOX folks always find something, don't you."

"That's the job," Nadia said, lightly, the way you say a true thing you don't want to turn into a fight on the first meeting. "I'm not here to find something wrong with Denise. I'm here to find out whether the system could let someone — not necessarily Denise, not necessarily ever — create a vendor and pay that vendor without anyone else looking at it. That's a different question."

Roberto didn't answer that directly. He glanced toward the back of the room, toward a woman in her fifties with reading glasses pushed up into gray hair, entirely absorbed in her second monitor, entirely unaware she had just become the center of a sentence in a controls testing narrative that would not resolve for months.

"Talk to Devon," Roberto said finally. "Talk to Security. If there's an access thing, that's not on my process, that's on how the roles were built."

Nadia nodded, and wrote nothing down yet — not here, not on the floor, in front of the person whose access she was about to question. That, too, was the job: knowing which things you noticed, and which things you recorded, were not always the same moment.

## CHAPTER 4

## The Access List

Devon Okoye's office was the only one on the floor with two monitors turned slightly toward each other, like a conversation frozen mid-sentence. He had the unhurried manner of someone who had built the thing he was now being asked questions about, and who took a quiet, private pride in knowing it better than the question-asker did — right up until the question-asker knew something he didn't.

"Priya's been in the SoD rule set with me since Tuesday," he told Nadia, when she stopped by. "Confirmed the ruleset's current post-merger — that was a good catch, by the way, whoever flagged that." He didn't know it had been Nadia, in a kickoff meeting three days earlier; she let it go.

"And the report?" Nadia asked.

Devon turned one monitor toward her. "Forty-one conflicts flagged organization-wide. Most of them are the boring kind — someone in a small plant wearing two hats because there's nobody else to wear the second one. Compensating controls on file for thirty-eight of them." `GRAC_ARA TECH NOTE` — Devon pulled this population using GRC Access Control's "Access Risk Analysis" app (or transaction in NWBC), run at the user level against the P2P SoD ruleset. If you were asked to reproduce this alone, that's the exact screen to open first.

"And the other three?"

Priya, at the second monitor, was the one who answered. She had a particular stillness when she'd found something real — the fast-talking energy of day one gone quiet and precise. "One of them is Accounts Payable. Denise Marsh. Vendor master maintenance and payment run execution, same user ID, both live, both unrestricted."

The room went, for a moment, very quiet in the specific way a room goes quiet when three people who understand exactly what a sentence means all understand it at the same time.

"That's a create-a-vendor-and-pay-it conflict," Nadia said. Not a question.

"That's a create-a-vendor-and-pay-it conflict," Devon confirmed. "Textbook. I built that role five years ago, before the merger, when AP was four people and everybody did everything. I should have caught it in the redesign. I didn't."

There was no defensiveness in how he said it, which Nadia noted and respected — a smaller man might have reached for an excuse first and the truth second. Devon had gone straight to the truth.

"Compensating control?" Nadia asked.

Priya shook her head. "Nothing on file. I checked the mitigation library twice."

Nadia looked at the flagged line on the screen — a row of data, a name, a role, a gap that had existed, unremarked, for five years, through no particular villain's doing, the way most control gaps come into being: not from malice, but from a merger and a headcount and a Tuesday when nobody had time to look closely.

"Okay," she said. "Log it. Today's date, today's finding, exactly as it stands right now — no softening it, no waiting to see if it's a big deal before we write it down. We write it down because it's true, not because we've decided yet what to do about it."

Priya was already typing. Somewhere in the GRC deficiency tracker, in a field that would eventually be read by an internal auditor, an external auditor, a compliance director, and — though none of them knew it yet — a CFO, a new row appeared. Stage zero. The clock, from that keystroke forward, had started.

### STOP AND DECIDE — BEFORE YOU KEEP READING

*Put the book down and answer these before you find out what Chapter 5 actually did.*

1. What exactly has Nadia found so far — in one sentence, without judgment words like "bad" or "serious"?
2. What risk does this specific access combination create for Thornfield's financial statements?
3. What would you ask Devon before you ask Roberto?
4. Is this an exception or a deficiency at this stage — and what's missing that would let you decide?

### YOUR TURN — WRITE IT, DON'T JUST THINK IT

Write the exact tracker entry you would log today — the one Nadia insists on: today's date, today's finding, exactly as it stands, with no judgment about how serious it is yet, and no conclusion about what happens next.

— write your version below before reading on —

### MODEL ANSWER — COMPARE YOUR VERSION

*Date: [today's date]. Finding: User Denise Marsh holds both vendor master maintenance (FK02/XK02) and payment run execution (F110) access within the same role, with no mitigating control on file. Population and full role history not yet tested. Status: Logged for follow-up — no conclusion reached.*

Notice what this version doesn't do: it doesn't say "bad," "serious," or "concerning." It doesn't assign blame. It doesn't propose a fix. It states exactly what was found and exactly what isn't known yet — which is precisely what Nadia asked Priya to write, word for word, in this chapter.

## CHAPTER 5

# Pushback

Roberto did not raise his voice. That was, Nadia would later think, the thing that made it worse, not better — a loud objection burns off fast, but a calm one settles in and stays.

"You're telling me," he said, in the small meeting room he'd chosen instead of his own office, "that after five years of clean audits — pre-IPO audits, mind you, real scrutiny — you want me to tell Denise she can't do half her job anymore, over something that's never once been a problem?"

"I'm not telling you to change anything today," Nadia said. "I'm telling you what the access design allows, not what's happened. Those are different sentences, and I need you to hear the difference, because the auditors will make you hear it eventually whether I say it gently now or not."

"It's academic," Roberto said. "It's a hypothetical."

"It's a hypothetical until it isn't," Nadia said. "That's true of every control gap that ever became a headline. Nobody plans the fraud around the gap. The gap just sits there, and one day somebody who isn't Denise — somebody new, somebody desperate, somebody who found the gap by accident — uses it. The control isn't there to catch Denise. It's there so it doesn't matter who's sitting in that chair."

Roberto was quiet for a moment, turning his coffee cup a quarter turn on the table, an old habit of a man working through something he didn't want to say out loud yet.

"You know what this looks like from where I sit," he said finally. "It looks like a new person, three weeks in, telling me my team's been doing it wrong for half a decade, and now I've got to go explain to Denise — who has been loyal to this company since before it was a company anyone wrote about — that she's suddenly a risk."

"She's not the risk," Nadia said, and meant it fully this time, without the earlier softness that had let him half-hear it as a hedge. "The design is the risk. I need you to help me fix the design without making Denise feel like she's on trial for it. That's not academic. That's the actual ask."

Roberto studied her for a moment — the particular look of a man deciding whether the person across the table is an adversary or, possibly, despite every instinct telling him otherwise, someone actually trying to help him.

"Fine," he said, standing. "But I want to be in the room when this goes wherever it's going next. I'm not finding out from a report that my process has a finding on it."

"You'll be in the room," Nadia said. "Every time."

It was, she would think later, the sentence that mattered most in the whole conversation — not the explanation of the risk, which he'd have gotten from the audit committee eventually whether he trusted her or not, but the promise that he would never be surprised by his own

finding. That was the thing that turned a business process owner from an obstacle into a partner. Not agreement. Just no surprises.

**STOP AND DECIDE — BEFORE YOU KEEP READING**

*Put the book down and answer these before you find out what Chapter 6 actually did.*

1. Roberto is pushing back. What do you say in the room, in one or two sentences?
2. What must you not promise him, no matter how reasonable his pushback sounds?
3. What do you write down about this conversation before you talk to anyone else?

## CHAPTER 6

## The Manager's Call

Grace's office had a whiteboard covered in a diagram Nadia hadn't yet asked about — arrows connecting boxes labeled things like BOARD REPORTING and Q3 CERT, the private cartography of a person managing risk two and three levels above where Nadia sat.

"Walk me through it," Grace said, closing her laptop fully, which Nadia had learned in three weeks was Grace's tell for this matters, I'm not half-listening.

Nadia laid it out plainly — the conflict, the five years it had existed, Devon's ownership of the original design gap, Roberto's initial pushback and the ground they'd found by the end of the conversation. She did not soften the finding and did not dramatize it either. Just the facts, in the order they'd happened.

Grace listened without interrupting, which was, Nadia was learning, a rarer management skill than it sounded — most managers wanted to solve the problem in real time, cutting in with fixes before the picture was even fully drawn. Grace let the picture finish.

"Is it a deficiency or a significant deficiency?" Grace asked, once Nadia had finished. "Your read, not the textbook read."

"My read — it's significant. Not material, not yet, we haven't found evidence it's ever been exploited. But the access existed, unrestricted, on a process that touches cash going out the door. If I were the external auditor, I wouldn't let this one go quietly."

Grace nodded slowly. "Neither would I, if I were them. Here's what I need from you. I need this logged formally — you've already done that, good. I need a remediation plan, not just a finding, before this goes anywhere near Internal Audit's radar, because a finding without a plan reads as a problem, and a finding with a plan reads as a program that's working exactly as designed. Those are very different meetings."

"Devon and I already have a rough shape for it," Nadia said. "Split the role — vendor master maintenance stays with Denise, payment run execution moves to a second person, with a compensating review of any new vendor added within the same run cycle until the split is fully live."

"Good. Get Ray looped in on timeline — this touches his tracker whether he likes it or not. And Nadia — " Grace paused, and for the first time in the conversation, something almost like relief crossed her face, quickly covered. "This is exactly the kind of thing I was worried we wouldn't catch until External Audit found it for us in October, with three months left to fix it and a lot less goodwill in the room. You found it in week three. That matters more than you probably know yet."

Nadia didn't say anything to that, but she carried it out of the office with her — the particular, unglamorous satisfaction of having done the quiet part of the job correctly, the part nobody claps for, the part that only shows its value in the disaster that, because of it, never happens.

## CHAPTER 7

**The Grind**

May slid into June the way it always does in the middle of a testing cycle — not a turning of a page so much as a long, undifferentiated stretch of workpapers, evidence requests, and the particular fatigue of doing careful work at volume.

Marcus's world had become transport logs. He'd built, without being asked, a running log of every evidence request to Ilse Tan in Basis — date requested, date promised, date received, a small monument to his own preference for order in a job that constantly threatened not to have any. "She's good," he told Nadia one afternoon, "but she's not going to treat my deadline like it's her emergency, and I don't blame her. Production doesn't wait for me. So I ask early, and I ask precisely, and I don't ask twice for the same thing."

It was, Nadia thought, the single most mature sentence she'd heard from any of the three juniors so far, and she told him so, plainly, the way she'd learned mattered more than people expected — specific praise, not vague warmth, landed like something you could actually use.

Priya, meanwhile, had become the de facto owner of everything touching the Access List finding — tracking Devon's role redesign, drafting the retest plan before anyone had asked her to, staying two steps ahead of a deficiency that, by now, had a name inside the team: the Denise finding, though never once in front of Roberto, who had earned, in the weeks since, the right not to hear his AP team's name attached to a problem like a scar.

Théo was the one who worried Nadia.

Not because his work was bad — it wasn't. But he had a habit, in walkthroughs, of answering a business process owner's question about timing with more certainty than he actually had. "Sure, we can have that reviewed by Friday," he'd told a procurement manager the week before, a promise that had nothing behind it but his own desire to be the kind of consultant people liked leaving a room with.

Nadia caught it in a hallway on a Tuesday. "You told Procurement we'd have their walkthrough notes back Friday."

"I mean — yeah, I figured we could — " Théo started, and then, watching her face, stopped defending it and just said, "I don't actually know if that's true. I said it because he looked stressed and I wanted to make it better."

"That instinct isn't wrong," Nadia said. "Wanting to make someone's day easier is a good instinct. But every commitment you make on my team's behalf is a commitment I now have to keep, whether I agreed to it or not, because you said it with my team's name behind it. From now on — anything with a date attached, you check with me before you say it out loud. Not because I don't trust you. Because a promise you can't keep costs more goodwill than an honest 'let me check' ever will."

Théo nodded, chastened but not crushed — Nadia had learned, by now, exactly how much weight he could take in one sitting, and had calibrated for it — and by Friday, the walkthrough notes were, in fact, late, and Théo was the one who called Procurement himself to say so, two days ahead of the deadline he'd invented, instead of on the day it quietly failed to arrive.

It was a small thing. It was also, Nadia thought, watching him make that call through the glass wall of their room, exactly the kind of small thing that either got fixed at twenty-six or calcified into a pattern that followed a person for the rest of a career.

## CHAPTER 8

## Internal Audit Steps In

Yusuf Bello read workpapers the way other people read contracts — slowly, twice, and with a pen that made small marks in margins that meant nothing to anyone but him until the moment he explained them, at which point they meant everything.

"Walk me through your sample selection on the Access List remediation retest," he said, in a conference room that had, by August, become something like neutral territory between Internal Audit and the controls team — not adversarial, exactly, but not casual either.

Priya, who had asked to lead this meeting herself, laid out the methodology: population of all vendor and payment-run access changes since the role split went live, a sample sized to the risk, not just a round number picked to look thorough.

Yusuf made one of his small marks. "Why that sample size, specifically?"

"Because a smaller sample on a remediated significant deficiency doesn't give us — or you, or External Audit — enough confidence that the fix actually held under real operating conditions, not just on paper," Priya said. "We under-sampled once on a different finding earlier this year. Nadia made us redo it. I'd rather over-ask you a question now than under-test and have to explain that later."

Something in Yusuf's expression shifted — not quite a smile, but its structural cousin. "That's the right answer," he said. "Most people your level give me the round number and hope I don't ask why."

Nadia, sitting slightly back from the table, felt the particular, quiet pride of watching a junior consultant hold her own in a room built specifically to test whether she could. This was the whole point of the last four months — not that Priya could execute a test, but that she could defend one, under real scrutiny, without Nadia's voice doing the work for her.

"One more thing," Yusuf said, closing his notebook. "I want to see this finding's full history — not just the remediation, the original discovery, the pushback, the plan, all of it, in order. Internal Audit doesn't just care whether you fixed it. We care whether your program catches things like this reliably, or whether this one was luck."

"It's all in the tracker," Nadia said. "Every stage, dated, from the day Priya first flagged it."

Yusuf nodded, satisfied in the particular, undemonstrative way of a man whose job was built entirely around not being easily satisfied. "Good. Because External Audit is going to ask me the same question in six weeks, and I'd rather already know the answer than go find out live in the room with them."

**STOP AND DECIDE — BEFORE YOU KEEP READING**

*Put the book down and answer these before you find out what Chapter 9 actually did.*

1. Internal Audit is now involved. What changes about how you document this finding?
2. What evidence would prove the access gap is real, not just theoretical?
3. What would you say to Yusuf if he asks whether this is "a big deal"?

## CHAPTER 9

## The Auditors From Kestrel & Marsh

Claire Whitmore arrived in October with the unhurried precision of someone who had done this exact engagement, in some version, at forty other companies, and had long since stopped being impressed or alarmed by any particular flavor of chaos a first-year public company could produce.

"Walk me through your ITGC access testing," she said, on the first morning of interim fieldwork, in a tone that made clear she had already read the workpapers and was now testing whether the person in front of her actually understood them, or had merely produced them.

Nadia had prepared for this the way she prepared her team for every audit interaction: not by rehearsing answers, but by making sure the underlying work could survive a question from any direction, at any depth.

"We identified a significant SoD conflict in Accounts Payable in May," Nadia said. "Vendor master maintenance and payment run execution on a single user ID, no compensating control on file. We logged it the day it was found, remediated the role design by July, and completed a retest in September with a sample sized to the risk, reviewed by Internal Audit before External Audit fieldwork began."

Claire made a note — not, Nadia had learned to recognize by now, a bad note or a good note, simply a note, the tool of a profession built on leaving nothing to memory. "Show me the original finding, exactly as it was logged the day it was found. Not the cleaned-up version. The first version."

This was, Nadia knew, the moment that separated a controls program that could withstand scrutiny from one that only looked good in retrospect. She pulled the original entry — dated, timestamped, in Priya's own unedited words from four months earlier, before anyone had smoothed a single sentence of it for an audience.

Claire read it. Read it again. "This is unusually direct for a first pass," she said. "Most companies soften the initial write-up once they realize how it's going to look."

"We write it down the day we find it, exactly as it is," Nadia said. "Before anyone's decided what to do about it. That's a rule on this team, not a suggestion."

"Whose rule?" Claire asked, and there was something almost like genuine curiosity in it now, not just the audit-question kind.

"Mine," Nadia said. "But it's not a new idea. It's just the only version of this job that holds up under a question like the one you just asked me."

Claire didn't say anything else about it directly — auditors rarely give you the satisfaction of a compliment — but three weeks later, in the formal walkthrough of the reliance testing results, the Accounts Payable finding was cited by name as an example of a control identified and

remediated within the same fiscal year, with no reperformance exceptions in External Audit's own independent sample. It did not become the material weakness Nadia had once, quietly, feared it might.

It became, instead, a single clean line in a much larger report — the kind of line that only exists because, months earlier, a room had gone quiet at the right moment, and someone had written the truth down before deciding whether they liked it.

## CHAPTER 10

## The CFO's Office

Nadia had never met Diane Whitfield before the day Grace asked her to sit in on the quarterly reporting package review — not to present, Grace was clear about that, just to sit in, in case a technical question came up that only Nadia could answer cleanly.

Diane's office was smaller than Nadia had expected, and busier — three monitors, a whiteboard with a countdown to year-end certification written in the corner in a handwriting too neat to be spontaneous, the handwriting of someone who had written that same countdown, in some form, every quarter of her career.

"Walk me through the deficiency log," Diane said, without much preamble, scanning the summary page Grace had prepared. "Just the significant ones. I don't need the small stuff, I need to know what's still open going into year-end."

Grace walked her through it, cycle by cycle, and when she reached the Accounts Payable finding — remediated, retested, cited favorably by External Audit — Diane paused on it longer than the others.

"This is the one from the spring," she said. Not a question, exactly, more a small act of memory, the recognition of a name she'd apparently heard once before, in some earlier, less detailed briefing.

"Found in week three of the engagement," Grace said. "Fully remediated and retested before interim fieldwork. External Audit noted it favorably."

Diane looked up, not at Grace, but past her, toward Nadia, sitting slightly apart from the table in the particular posture of someone who has been told explicitly not to speak unless spoken to. "You're the one who found it?"

"My team found it," Nadia said, carefully, and meant the correction — Priya had pulled the report, Priya had asked the question that mattered, and Nadia was not going to let a CFO's passing sentence quietly erase that. "I was three weeks into the job. It was Priya Nair, on my team, who flagged it."

Something in Diane's expression — brief, almost imperceptible, gone as quickly as it arrived — was the look of an executive filing away a name she had not expected to need, in case she needed it later. "Make sure that's noted somewhere that isn't just my memory of this meeting," she said, to Grace now. "I'd like the certification narrative to reflect that this program is finding things, not just passing things. That's the difference between a controls function that's decorative and one that's real."

It was the closest thing to a review Nadia's team would ever receive from the person whose signature, ultimately, all of this existed to support — a single sentence, in a room they were barely present for, that would never appear in any performance document, and that mattered more than most things that would.

## CHAPTER 11

## Rebuilding the Role

The actual work of remediation, when it finally happened, was almost anticlimactic after everything that had led to it — which was, Nadia had come to believe, exactly how the best remediations always felt. The drama lived in the discovery and the escalation. The fix itself, done right, was quiet.

Devon and Roberto had, somewhere in the intervening months, gone from a Security analyst and a Business Process Owner who barely knew each other's names to something closer to a working partnership, forged in the specific way two people are forged by solving the same uncomfortable problem together.

"We split the composite role into two," Devon explained, walking Nadia and Priya through the redesign on his second monitor. "Vendor master maintenance stays with Denise. Payment run execution moves to Carlos — he's been in AP two years, solid record, no other conflicting access. And until the split's been live a full quarter, any new vendor added within the same week as a payment run triggers an automatic email to Roberto for review."

"Denise know yet?" Nadia asked.

Roberto, who had joined the call from his desk, answered that one himself. "I told her myself, two weeks ago. Told her straight — this isn't about her, it's about what happens after she retires someday and somebody I've never met inherits her badge. She actually said she was relieved. Said she'd wondered for years why nobody ever asked about it before."

Nadia let that sit for a moment. Five years of an unquestioned gap, and the person at the center of it had wondered, quietly, the whole time, why no one had ever asked. It was, she thought, one of the more honest things anyone had said in this entire engagement — and it had come from the person with the most reason to be defensive about it.

"That's the compensating control logged, the role split live as of the fourteenth, and the review email tested twice this week," Priya said, checking items off a list she'd built without being asked. "I want to run the retest in three weeks, once we've got a real cycle of data instead of just the test transactions."

"Approved," Nadia said. "Document the whole redesign — not just what changed, but why, in Devon's own words if he'll give them to you. When External Audit or next year's team asks why this control exists, I want the answer to be more than 'because SOX said so.' I want it to be because five years ago nobody asked, and this year, someone did."

**STOP AND DECIDE — BEFORE YOU KEEP READING**

*Put the book down and answer these before you find out what Chapter 12 actually did.*

1. Before Roberto's team can rebuild the role, what should the remediation plan actually specify?
2. What would make a remediation plan sufficient versus just a promise to do better?

## CHAPTER 12

**Retest**

Priya ran the retest in the second week of September, and this time, Nadia did not sit in the room.

It was a small decision with a larger meaning behind it — the kind of trust a manager extends not because the outcome is guaranteed, but because the only way a junior consultant becomes a senior one is by being handed something that actually matters and being allowed to own it, mistakes and all.

Priya pulled the population — every vendor master change and payment run since the role split, a full quarter's worth of real operating data, not test transactions — sized her sample against the risk the way Yusuf had taught her to defend, and walked the evidence herself: system logs showing Denise's access now excluded from payment run execution, Carlos's access excluded from vendor master maintenance, four instances in the quarter where a vendor was added within the same week as a run, and four matching review emails to Roberto, each with a documented response.

She found one exception. A small one — a review email that had gone to Roberto's inbox but sat unopened for six days before he'd caught it during a routine check, rather than the same-day review the control called for.

She brought it to Nadia not as a problem to be smoothed over, but exactly the way she'd been taught to bring everything: plainly, and already logged. "It's not a failure of the control," Priya said. "The control worked — it flagged the transaction. It's a timeliness gap in the response. I think we note it, and I think we ask Roberto whether he wants a backup reviewer for the days he's traveling, since that's what happened here."

Nadia read the finding, read Priya's proposed resolution, and felt something she hadn't quite expected to feel this early in the year — not relief exactly, and not pride exactly, though it was closer to pride than anything else. It was the specific satisfaction of watching someone you have coached do, unprompted, precisely the thing you spent months teaching them to do: find the truth, write it down as it is, and propose a fix that solves the actual problem instead of just making the finding disappear.

"That's exactly right," Nadia said. "Take it to Roberto yourself. You found it, you own the conversation."

Roberto, when Priya brought it to him that afternoon, didn't push back at all — a small, telling measure of how far the relationship had traveled since May. "Backup reviewer makes sense," he said. "I'll name one by Friday. Good catch. Tell Nadia I said her team's gotten sharp."

Priya did tell her, word for word, a little proud of the message she was carrying, and Nadia let herself, just for a moment, feel the whole arc of it — from a splinter of a sentence on a factory floor in April to a backup reviewer named in September — the way it looks when a program actually works.

**STOP AND DECIDE — BEFORE YOU KEEP READING**

*Put the book down and answer these before you find out what Chapter 13 actually did.*

1. What evidence would prove the remediation actually held, not just that it was implemented?
2. If you were writing the retest conclusion right now, what would the closing sentence say?

**YOUR TURN — WRITE IT, DON'T JUST THINK IT**

Before you read what Priya actually wrote, draft your own two- to three-sentence retest conclusion: state whether the control operated, note the one exception found, and propose a resolution.

— write your version below before reading on —

**MODEL ANSWER — COMPARE YOUR VERSION**

*Retest Conclusion: The compensating control (secondary review of vendor master changes concurrent with payment runs) operated throughout the quarter. One exception noted — a review email sat unactioned for six days before detection during a routine check, versus the same-day review the control requires. This is a timeliness exception, not a control failure; the control did flag the transaction. Recommended resolution: designate a backup reviewer for periods when the primary reviewer is unavailable, per discussion with the process owner.*

Notice the shape: what worked, stated plainly — the one thing that didn't, stated just as plainly — and a fix aimed at the actual cause (an unavailable reviewer), not a vague promise to "be more careful." That's the same shape every workpaper conclusion in Part 6 of this guide asks you to produce.

## CHAPTER 13

**Close**

The last week of the fiscal year had the particular texture that year-end always has in a controls function — not the loud drama of a fire drill, but a dense, quiet accumulation of finishing: final workpapers filed, final reviews signed, final numbers in the tracker turning, one by one, the green that Ray had wanted since May.

Nadia spent most of it reading, not writing — reviewing her team's work one last time before it became part of a record that would outlive the year itself, that some future team member, new to Thornfield the way she had been eleven months earlier, might one day pull up as the prior-year documentation.

The Accounts Payable finding closed formally on a Tuesday, with a line in the deficiency tracker that read, in full: Identified 5/14. Remediated 7/22. Retested 9/18, one timeliness exception noted and resolved. No repeat exceptions in Q4 monitoring. Closed. It took four lines to summarize five months of a story that had, at various points, involved a factory floor, a defensive business process owner, a Security analyst's quiet ownership of an old mistake, a CFO's passing remark in a room she was barely present for, and a junior consultant's first real, unsupervised win.

Grace found her in the glass room on the last afternoon, the paper CONTROLS TEAM sign still taped, a little more crooked now, to the door. "Certification's signed," Grace said. "Diane signed it an hour ago. No material weaknesses. Two significant deficiencies identified and remediated during the year — including yours from May — which the board actually likes seeing, believe it or not. It tells them the program's alive, not just clean on paper."

"How'd Kestrel and Marsh land on the overall opinion?" Nadia asked.

"Clean," Grace said. "Claire Whitmore's exact words to me were, and I'm quoting her because I wrote it down specifically to tell you: 'This is the most credible first-year SOX program I've seen from a company your size in a while. Your team finds its own problems. That's rare.'"

Nadia looked across the room — Marcus, closing out his last transport log of the year with the same unhurried care he'd brought to his first one in May; Théo, on the phone with a business process owner, this time saying, clearly and audibly, "let me check and get back to you by end of day" instead of promising something he didn't yet own; Priya, already, unprompted, sketching a rough plan for next year's cycle on the whiteboard, because eleven months in, she had stopped waiting to be told what came next.

"They didn't find their own problems," Nadia said, quietly, mostly to herself. "We built a team that finds its own problems. There's a difference, and it's the only part of this whole year I actually take credit for."

Grace didn't argue with that. She just nodded, once, the way she had on day one when Nadia had asked the right question in her first kickoff meeting, and left her to close out the year with the team she'd built it with.

**EPILOGUE****What Nadia Wrote Down**

On her last afternoon before the winter holiday, Nadia opened a blank document — not a workpaper, not a tracker entry, just a page — and wrote a short note that she would later hand, unedited, to the first new hire who ever sat in that glass room after her.

If you are reading this on your first week, here is what I wish someone had told me on mine:

The work is never really about the system. SAP, GRC, the tracker, the RCM — those are just where the truth happens to live this year. The work is about the people around the system: the business process owner who is not your enemy even when he sounds like one at first, the Security analyst who owns his old mistakes without flinching, the junior consultant who needs you to catch a small bad habit before it becomes a permanent one, the manager who needs you to bring her risk early and undecorated, and the auditor who will only ever trust the version of the story you wrote down on the day you found it — not the version you wish you'd found instead.

Write it down the day you find it. All of it, exactly as it is, before you know yet whether you like it. Everything else in this job — the escalation, the remediation, the retest, the closing line in the tracker that takes four sentences to hold five months — everything else is just what happens after that first honest sentence gets written.

Somewhere in your first year, there will be an access list, or something like one. A gap nobody meant to create. Find it. Say what it is, plainly, to the person it belongs to. Help them fix it without making them feel accused. Write down what changed and why. Test that it held. And then let it go, and let your team learn to do it without you, because that is the only version of this job that actually scales past you.

That's the whole story. Everything else is just the year it took to tell it.

She saved the document under a single word — ACCESS — and closed her laptop for the year.

## Part 2 — Team Job Descriptions & Working Relationships

### *Know your team before day one*

This is the same working-relationships framework TIB Systems uses for a Senior SOX/ITGC Controls Lead, rewritten for the person actually running the SAP transactions, pulling the evidence, and building the workpapers — you.

#### **THE ONE RULE THAT MATTERS MOST IN YEAR ONE**

Everything you find, you route through your Senior Lead first — not because you can't be trusted, but because your Senior is the one holding the full picture of what's already been escalated, what's already being negotiated with External Audit, and what a Business Process Owner has already been told. You earn direct relationships with Basis, Security, and BPOs over your first year. You don't start with them.

### Quick-Reference: Relationship Matrix

| Role                          | Relationship Type                                 | What This Means in Practice                                                                       |
|-------------------------------|---------------------------------------------------|---------------------------------------------------------------------------------------------------|
| Senior SOX/ITGC Controls Lead | Your Direct Reviewer & Escalation Path            | Reviews every workpaper before it's final; invest here first                                      |
| Fellow Junior Consultants     | Peer Ally / Second Set of Eyes                    | Trade reviews before your Senior sees the work                                                    |
| Compliance Director           | Two Levels Up — Escalate Only Through Your Senior | You'll rarely interact directly; that's normal                                                    |
| PM                            | Schedule Coordinator                              | Your Senior owns this relationship; you report status upward through them                         |
| SAP Basis Team                | Evidence Source — Route Through Your Senior First | Don't cold-email Basis your first month; learn the relationship through your Senior               |
| SAP Security Team             | Evidence Source for Access Testing                | Your primary partner once you're independently running SoD tests                                  |
| Business Process Owners       | Interview Subject — Be Precise, Be Brief          | They're busy; a clear, specific ask earns trust fast                                              |
| Internal Audit                | Reviewer of Your Senior's Conclusions             | You'll rarely present directly to them in year one; your work still has to survive their scrutiny |
| External Audit                | Never Direct Contact Without Your Senior Present  | The fastest way to look inexperienced is committing to anything with them unsupervised            |

### ***Your Senior SAP SOX/ITGC Controls Lead***

**RELATIONSHIP TYPE: Direct Reviewer & Escalation Path — This Relationship Is Everything**

*Reports To: N/A (this is who you report to) | Manages / Oversees: You, and your fellow junior consultants*

**Mission**

Own the overall testing cycle's accuracy, timeliness, and defensibility — which in practice means reviewing every workpaper you produce before it becomes evidence anyone outside the team ever sees.

**Key Responsibilities**

- Assign your testing workload and the specific transactions/evidence you're responsible for pulling.
- Review your workpapers for completeness, accuracy, and defensibility before anything moves to Internal or External Audit.
- Coach you on judgment calls — what counts as a finding, how to size a sample, how to talk to a Business Process Owner.
- Escalate anything you find that's bigger than your own workstream to the Compliance Director.

**Where You Can Expect Their Support**

- Your first and best resource when an SAP transaction doesn't show what you expected it to show.
- Your buffer with every external stakeholder — Basis, Security, BPOs, Internal Audit, External Audit — until you've earned standing to interface with them independently.
- The person who will absorb pressure from above so you can focus on getting the testing right.

**Where Friction Is Normal — Watch-Outs**

- It's tempting to soften a finding before bringing it to your Senior, to avoid looking like you missed something — resist this. Bring it exactly as you found it.
- Your Senior's review will sometimes send your work back for rework. This is normal, expected, and how the standard gets set — it is not a signal you're doing poorly.

**How and When to Escalate**

This is your escalation path for almost everything in year one. Bring questions, half-finished findings, and things that don't look right — don't wait until you're sure before you ask.

**Fellow Junior Consultants****RELATIONSHIP TYPE: Peer Ally / Second Set of Eyes**

*Reports To: Same Senior Lead as you | Manages / Oversees: No reports*

**Mission**

Execute their own assigned testing workstream, while building the same judgment and technical fluency you are.

**Key Responsibilities**

- Own their own testing area (access, change management, R2R, or whichever scope you've each been assigned).

- Review each other's workpapers informally before either of you brings work to your Senior.

### **Where You Can Expect Their Support**

- The fastest way to learn a transaction or GRC screen you haven't used yet is often a five-minute conversation with a peer who has, rather than waiting for your Senior's time.
- A second set of eyes catches the same kind of small errors your Senior would otherwise have to catch — use each other before every formal review.

### **Where Friction Is Normal — Watch-Outs**

- Comparing your pace or confidence to a peer's is natural and unhelpful — everyone's workstream has a different learning curve.

### **How and When to Escalate**

Peer-to-peer, always informal. Nothing about your working relationship with fellow juniors should ever substitute for your Senior's formal review.

## **SAP Basis Team**

### **RELATIONSHIP TYPE: Evidence Source — Route First Requests Through Your Senior**

*Reports To: IT Infrastructure Manager (a separate chain from yours) | Manages / Oversees: System landscape: transports, refreshes, batch jobs, backups*

### **Mission**

Keep the SAP system landscape stable — and, for your purposes, hold the transport logs, backup records, and system configuration evidence your change-management and computer-operations testing depends on.

### **Key Responsibilities**

- Execute and log system changes (transports).
- Run and monitor nightly backups, batch jobs, and system maintenance.
- Respond to evidence requests: transport logs, table extracts, backup completion reports.

### **Where You Can Expect Their Support**

- Once you're running your own evidence requests (typically after your first few weeks), Basis is your most direct technical partner — they can usually tell you in five minutes whether something you're seeing in STMS or SE01 is normal or not.

### **Where Friction Is Normal — Watch-Outs**

- Basis works its own ticket queue, prioritized by production stability — your evidence request is not automatically their most urgent item. Ask early, be specific, and never assume a same-day turnaround.

### **How and When to Escalate**

For your first month, route all Basis requests through your Senior so they can introduce you properly. After that, direct requests are normal — but any request that isn't being answered should go to your Senior, not straight to the Basis manager.

## **SAP Security / GRC Access Control Team**

### **RELATIONSHIP TYPE: Close Working Partner for Access Testing**

*Reports To: IT Security Manager or GRC Platform Owner (a separate chain from yours) | Manages / Oversees: Role design, access provisioning, SoD rule-set, firefighter/EAM administration*

#### **Mission**

Own the access control environment — role builds, provisioning, and the SoD rule set — that your GRC Access Risk Analysis and PFCG/SUIM testing evaluates directly.

#### **Key Responsibilities**

- Maintain the SoD rule set in GRC Access Control.
- Process access requests and role assignments.
- Administer firefighter/emergency access management.

#### **Where You Can Expect Their Support**

- Your primary partner for anything involving Access Risk Analysis, PFCG role detail, or a mitigating control question — they can usually confirm in minutes whether a flagged conflict already has documentation.

#### **Where Friction Is Normal — Watch-Outs**

- A flagged SoD conflict can land as implied criticism of how a role was built — frame every question as “help me understand how this role works,” not “why did you build it this way.”

#### **How and When to Escalate**

Work findings collaboratively at the analyst level. If a genuine gap isn't being addressed, that escalation decision belongs to your Senior, not to you directly.

## **Business Process Owners (BPOs)**

### **RELATIONSHIP TYPE: Interview Subject — Be Precise, Be Brief, Be Respectful of Their Time**

*Reports To: Their own functional VP or Director | Manages / Oversees: The day-to-day operation of controls within their process area*

#### **Mission**

Run their business process, including the controls embedded in it, and provide the evidence and interview access your testing requires.

#### **Key Responsibilities**

- Operate the controls in their process as designed.

- Provide evidence and participate in walkthroughs when requested.

### **Where You Can Expect Their Support**

- The single best source of real process knowledge — what a report or workpaper says a process does, and what actually happens day to day, are not always identical, and a good BPO conversation surfaces the difference.

### **Where Friction Is Normal — Watch-Outs**

- Never promise a BPO a deadline, a conclusion, or that “this is nothing to worry about” — that judgment belongs to your Senior. Your job is to ask precise questions and gather evidence, not to reassure.

### **How and When to Escalate**

If a BPO pushes back hard on a request, or a walkthrough surfaces something that feels bigger than routine testing, bring it to your Senior the same day — don’t try to resolve BPO pushback yourself.

## **Putting It All Together**

In your first year, almost every relationship on this list runs through your Senior Lead first, and that is by design, not a limitation on your growth. The consultants who make the fastest, most durable progress are the ones who use that first year to genuinely learn each relationship through their Senior’s example — watching how a finding gets framed to a BPO, how a request gets escalated to Basis, how a scope question gets handled with Internal Audit — before they’re ever asked to carry those relationships independently.

#### **RULE OF THUMB**

If you’re unsure whether something is yours to handle alone or something to bring to your Senior first, bring it to your Senior first. Nobody has ever been criticized in this program for asking too early. Several people have learned the hard way what happens when they didn’t.

## Part 3 — A Day in the Life

### *What running the actual tests looks like*

There is no single “typical day” — but there is a rhythm. As a junior consultant, your day is built around execution: pulling populations, running the transactions, capturing evidence, and documenting what you find, cleanly enough that your Senior can review it quickly.

### A Representative Day, Hour by Hour

| Time          | Block                               | What This Looks Like                                                                                                                                                                                                                          |
|---------------|-------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 8:00 – 8:30   | Inbox and Tracker Triage            | Check whether any evidence request you submitted to Basis or Security came back overnight. Check your Senior’s review comments on anything you submitted yesterday.                                                                           |
| 8:30 – 9:00   | Team Huddle                         | Report what you’re working on today, in specific transaction-level terms — “pulling the Q3 SoD population in GRC Access Risk Analysis, then cross-checking flagged users in PFCG” beats “working on access testing.”                          |
| 9:00 – 11:00  | Deep Work — Running the Actual Test | Log into the GUI or Fiori Launchpad, pull your population (FBL3N, SUIM, GRC Access Risk Analysis, or whichever transaction fits your assignment), export it, and begin working through your sample. Log as you go, not from memory afterward. |
| 11:00 – 12:00 | Evidence Request Follow-Up          | Chase anything you’re waiting on from Basis, Security, or a Business Process Owner. Be specific: the exact transport number, user ID, or document number, not a general description.                                                          |
| 12:00 – 1:00  | Lunch / Flex                        |                                                                                                                                                                                                                                               |
| 1:00 – 2:30   | Documentation                       | Convert your raw testing output into a workpaper your Senior can actually review — screenshots with transaction codes labeled, a clear statement of what you tested and what you found, dated.                                                |
| 2:30 – 3:30   | Senior Review Session               | Walk your Senior through anything unclear, anything that looks like a finding, or anything you’re not fully confident about. This is the actual mechanism by which your work becomes reliable evidence.                                       |
| 3:30 – 5:00   | Rework and Next-Day Prep            | Address review comments same-day where possible. Set up tomorrow’s transaction pulls so you can start immediately.                                                                                                                            |

#### THE REAL SKILL BEING TESTED

It isn’t memorizing every T-code on day one — it’s developing the instinct to notice when what a transaction shows you doesn’t quite match what you expected, and bringing that instinct to your Senior before you’ve talked yourself out of it.

## Five Testing Day-Types You'll Rotate Through

### 1. The Population-Pull Day

Heavy on FBL3N, SUIM, GRC Access Risk Analysis, or SE16N — building the full population for a testing cycle before sampling begins. Precision in your selection criteria matters more than speed; a wrong date range or filter means redoing the whole population later.

### 2. The Sample-Testing Day

Working through individual sampled items — opening FB03 documents, checking PFCG role detail, reviewing SWI1 workflow history. This is where most individual findings first surface.

### 3. The Evidence-Chase Day

Dominated by following up with Basis, Security, or a BPO for something you requested but haven't received. Document every request and response — a chase that takes three emails is itself evidence of how the underlying control's evidence trail actually works.

### 4. The Rework Day

Your Senior's review sent something back. This is normal and valuable — treat every rework cycle as the fastest way to calibrate your own judgment against the standard.

### 5. The Escalation Day

You found something that looks bigger than routine testing — a pattern across many transactions, not just one; a control that appears to have never actually worked; anything touching money moving or data leaving the company. Stop, document exactly what you found, and bring it to your Senior immediately.

#### YOUR CORE TOOLKIT

SAP GUI transactions (FBL3N, FB03, SUIM, PFCG, SE16N, SM37, STMS), the GRC Access Control Fiori apps (Access Risk Analysis, User Access Review, Firefighter Log Report), and your own testing tracker. The full T-code and Fiori app reference for every scope area is in the companion SAP Testing Execution Guide — keep it open in a second window during your first several cycles. Part 5 of this guide shows you exactly how.

*No two testing days look identical, but every day runs on the same loop: pull the right population, test it precisely, document it clearly, and bring anything uncertain to your Senior before you've decided for yourself whether it matters.*

## Part 4 — The First 30 Days

### *From new hire to trusted tester, transaction by transaction*

Your job is execution: running the actual SAP transactions, pulling the actual evidence, and building workpapers your Senior Lead can rely on. This part walks through your first 30 days — what you need to learn, which transactions to get comfortable with first, and how to start contributing real testing work without waiting to feel fully ready.

#### **MINDSET FOR MONTH ONE**

You are not expected to know every transaction code on day one. You are expected to be visibly learning — asking what a screen is showing you, double-checking your own selection criteria, and bringing your Senior anything that doesn't look right rather than guessing.

### **Week 1: System Access and Orientation**

#### **Goals**

- Get your SAP GUI and Fiori Launchpad access provisioned — this often takes several days, so request it day one.
- Meet your Senior Lead and fellow junior consultants.
- Understand which testing workstream you'll be assigned first (access, change management, or R2R).

#### **Suggested Actions**

- Log into SAP GUI and Fiori for the first time with your Senior or a peer present.
- Run your first read-only transactions under supervision: SE16N to display a table, SUIM to browse a user's role assignments, FB03 to open a posted document.
- Review the SAP Testing Execution Guide's Part I (Access Control) or Part II (Change Management) — whichever matches your first assignment — before your first real testing task.

#### **WEEK 1 DELIVERABLE**

Confirmed system access, and three or four practice screenshots — a SUIM user list, an FB03 document, an SE16N table pull — reviewed with your Senior so you know what "good" evidence documentation looks like before you're doing it solo.

### **Week 2: Your First Supervised Test**

#### **Goals**

- Run one complete test cycle — population pull through documented conclusion — with your Senior reviewing every step.
- Learn the specific transactions tied to your assigned workstream in depth.

#### **Suggested Actions**

- If you're on access testing: run GRC Access Risk Analysis for a single, small population, then use PFCG and SUIM to confirm the results manually for two or three sampled users.
- If you're on change management: pull one week of STMS import history, and use SE01 to open each transport and confirm its contents and release date.
- If you're on R2R: pull one month of journal entries above a threshold via FBL3N, and use FB03 to check each one's approval status.
- Ask your Senior to review your raw output before you write a single sentence of conclusion.

#### WEEK 2 DELIVERABLE

One fully supervised test cycle, start to finish, with your Senior's sign-off on both your transaction execution and your written conclusion.

### Week 3: Building Independence on One Test Type

#### Goals

- Run a second test cycle in the same workstream with less supervision.
- Start recognizing what a normal result looks like versus something worth flagging.

#### Suggested Actions

- Time yourself running the same transaction sequence you learned in Week 2 — speed matters, but never at the cost of double-checking your selection criteria.
- When you find something unusual, resist the urge to either dismiss it or panic. Write down exactly what you saw, with a screenshot, and bring it to your Senior to talk through.
- Start reading the SAP Testing Execution Guide sections for workstreams other than your own.

#### WEEK 3 DELIVERABLE

A second test cycle completed with lighter supervision, plus at least one instance of correctly flagging something uncertain to your Senior rather than either ignoring it or over-escalating it.

### Week 4: Your First Independent Assignment

#### Goals

- Own a small, complete piece of testing independently, from population pull to documented conclusion.
- Deliver your first status update in your own voice.

#### Suggested Actions

- Ask your Senior for a well-defined, appropriately sized piece of testing to run fully on your own.
- Build your own testing log exactly the way you were shown — transaction, date, selection criteria, findings — without being reminded.

- Identify one thing about the process you'd improve, and mention it to your Senior, even informally.

#### 30-DAY DELIVERABLE

One independently completed test cycle, reviewed and accepted by your Senior with minimal rework, and a working comfort level with the core transactions for your assigned workstream.

### This Looks Different Depending on Where You're Starting

The 30-day expectations above assume some prior exposure to either SAP or controls testing. If you're starting completely new to both, that's normal — talk to your Senior about which of these three outcomes is the realistic target for your first 30 days, and don't confuse a slower start with falling behind.

| Starting Point                        | Appropriate 30-Day Outcome                                             |
|---------------------------------------|------------------------------------------------------------------------|
| Audit/controls experience, new to SAP | Independently execute a narrowly defined test                          |
| SAP experience, new to controls       | Execute the SAP procedure and draft a supervised conclusion            |
| New to both SAP and controls          | Complete a highly supervised test and explain the reasoning accurately |

### 30-Day Checklist

- SAP GUI and Fiori Launchpad access confirmed and working.
- Able to explain the control objective, define the required population, select the appropriate SAP source, and validate its completeness — with SUIM, FB03, SE16N, and the core transactions for your assigned workstream as the tools underneath that, not the goal itself.
- Completed at least two fully or partially supervised test cycles.
- Completed at least one independent test cycle with minimal rework.
- Read the SAP Testing Execution Guide sections relevant to your workstream in full.
- Correctly escalated at least one uncertain finding to your Senior rather than guessing.

### Common First-Month Pitfalls to Avoid

- Running a transaction and accepting its output without checking your selection criteria actually captured the full population you intended.
- Waiting until a workpaper is "perfect" before showing it to your Senior — bring work in progress; that's what review time is for.
- Emailing Basis or Security directly in your first weeks before your Senior has introduced you to that relationship.
- Softening or second-guessing something you found in a transaction because it doesn't seem like it should be a big deal.
- Reconstructing your testing log from memory at the end of the day instead of logging as you go.

## Part 5 — The First 90 Days

### *From one workstream to real testing range*

By day 30 you could run your assigned workstream's core transactions independently and produce a workpaper your Senior could review quickly. The next sixty days are about depth and range: running full cycles without step-by-step supervision, cross-training into a second scope area, and developing the judgment to know when something you're seeing in a transaction is routine and when it's worth a second look.

#### **MINDSET FOR DAYS 31–90**

Month one was about learning where the buttons are. Months two and three are about developing a feel for what normal looks like in your data — which is the only way you'll ever reliably notice when something isn't normal.

### **Days 31–60: Owning a Full Cycle, Cross-Training a Second Area**

#### **Core Activities**

- Run a complete testing cycle in your primary workstream independently — your Senior reviews the finished product, not each step.
- Begin cross-training in a second scope area. If you started in access control, spend time learning STMS/SE01 (change management) or FBL3N/FB03 (R2R) alongside a peer who owns that area.
- Start directly requesting evidence from Basis, Security, or a BPO for routine items.

#### **Deepening Your Transaction Fluency**

- Move beyond the basic pull-and-check pattern: start using SUIM's more advanced selection criteria (by transaction executed, by authorization object).
- In change management, start cross-referencing SE01 transport contents against the actual change ticket system, not just confirming a ticket number exists.
- In R2R, start using SWI1/SWIA to trace a workflow's actual approval path, not just checking whether FB03 shows a completed status.

#### **DAYS 31–60 DELIVERABLE**

One full testing cycle owned independently in your primary workstream, plus meaningful hands-on exposure to a second workstream's core transactions.

### **Days 61–90: Judgment and Range**

#### **Core Activities**

- Take on testing in your second workstream with real (if still reviewed) ownership.
- Start recognizing patterns across your own testing — is this the third time this quarter you've seen a similar exception?

- Practice writing findings the way your Senior does: dated, factual, exactly as found, before anyone has decided what to do about it.

#### DAYS 61–90 DELIVERABLE

Demonstrated range across two workstreams, and at least one instance of independently recognizing a pattern or connection across multiple testing items that your Senior found genuinely useful.

### Your Growing Capability, With the Toolkit Underneath It

The measure of day 90 isn't how many transactions you recognize — it's whether you can define a population, validate it, test it, and defend a conclusion in each area below. The transactions are how you do that, not the target itself.

| Area                | Core Transactions / Apps                           | What You Should Be Able to Do Unassisted                                            |
|---------------------|----------------------------------------------------|-------------------------------------------------------------------------------------|
| Access Control      | SUIM, PFCG, GRC Access Risk Analysis, SE16N        | Pull a full SoD population and independently confirm a flagged conflict             |
| Change Management   | STMS, SE01/SE09/SE10, SE03                         | Reconcile a transport population against approval tickets                           |
| Record to Report    | FBL3N, FB03, SWI1/SWIA                             | Pull a journal entry population and confirm approval workflow completion            |
| Computer Operations | DB13, DB12, SM37                                   | Confirm backup job completion status and identify a failed batch job                |
| GRC Platform        | GRC Process Control apps, GRC Risk Management apps | Navigate the Process Control exception reports and Risk Register with basic fluency |

### Stakeholder Interface Cadence

| Stakeholder               | Frequency                      | What Changes by Day 90                                                       |
|---------------------------|--------------------------------|------------------------------------------------------------------------------|
| Senior Lead               | Daily to weekly                | Reviews finished cycles, not step-by-step work                               |
| Fellow Juniors            | Daily                          | Cross-training partners, not just peer reviewers                             |
| Basis Team                | As needed                      | Direct requests for routine items, introduced relationships for anything new |
| Security Team             | Weekly in-cycle                | Direct working relationship for access testing                               |
| Business Process Owners   | Per cycle                      | Independent walkthroughs for routine items                                   |
| Internal / External Audit | Rare, only with Senior present | Still not a direct relationship — this develops in year two and beyond       |

## 90-Day Milestones Checklist

- Independently owned at least one full testing cycle in your primary workstream.
- Meaningfully cross-trained in a second scope area's core transactions.
- Built a direct, functioning working relationship with Basis and/or Security for routine evidence requests.
- Recognized and correctly escalated at least one pattern across multiple testing items, not just a single isolated exception.
- Produced workpapers your Senior can review quickly, with minimal rework, on a consistent basis.

## Part 6 — The Workpaper & Evidence Reliability

*What you actually have to produce, and why the report in front of you might not be enough*

Everything so far has told you that your job produces a workpaper. This part teaches you what one actually contains, and the questions a real workpaper has to answer before anyone — your Senior, Internal Audit, External Audit — will trust it.

### WHY THIS COMES BEFORE THE ONLINE COURSE

The online course teaches you exactly which SAP screen produces the evidence. It does not teach you whether that evidence is good enough on its own. That judgment is a separate skill, and it's the one that actually distinguishes a consultant from someone who can just run a T-code.

### The Standard Workpaper, Field by Field

Every test you run — in every scope area, for the rest of your career — produces a workpaper with some version of these fields. Learn the shape once and you'll recognize it in every Book of the online course.

| Field                                | What Belongs There                                                                                     |
|--------------------------------------|--------------------------------------------------------------------------------------------------------|
| Control ID and description           | Exactly which control you're testing, in the same words the control matrix uses.                       |
| Business risk                        | What could go wrong in the business if this control failed — not the SAP mechanics.                    |
| Control objective                    | What the control is designed to prevent or detect.                                                     |
| Process owner and control owner      | Who runs the process, and who is accountable for the control operating.                                |
| Testing period                       | The exact date range your population and conclusion cover.                                             |
| Population definition                | What population you tested, defined precisely enough that someone else could rebuild it.               |
| Population source                    | Which system, report, or transaction the population came from.                                         |
| Completeness and accuracy validation | How you confirmed the population is the whole population, not just what the report happened to return. |
| Sampling approach                    | How you selected your sample from the population, and why that approach is appropriate.                |
| Procedures performed                 | The actual steps you took, in enough detail to be reproducible.                                        |
| SAP transaction or report used       | The specific T-code, Fiori app, or GRC screen — this is one line, not the whole workpaper.             |
| Evidence references                  | Screenshots, exports, or documents, each labeled and dated.                                            |
| Results by sample item               | What you found for each item tested, not just a summary.                                               |
| Exceptions                           | Anything that didn't match what the control should have produced.                                      |

| Field                  | What Belongs There                                                                                    |
|------------------------|-------------------------------------------------------------------------------------------------------|
| Management explanation | What the process owner said about any exception, recorded as given — not softened or agreed with yet. |
| Tester conclusion      | Your own conclusion, written before your Senior tells you what to think.                              |
| Reviewer notes         | Your Senior's comments — this field is theirs, not yours to fill in.                                  |
| Final disposition      | What ultimately happened: closed, remediated, escalated, or carried forward.                          |

#### THE MOST COMMON JUNIOR MISTAKE IN THIS LIST

Writing "SAP transaction used" as if it were the whole workpaper, and leaving population definition, completeness validation, and tester conclusion thin or missing. The transaction is one line. Everything around it is the actual evidence of your judgment.

### Is the Evidence Actually Reliable?

A common junior mistake is assuming that because SAP produced a report, the report is complete and reliable. It might be. It might also be missing records, generated by the wrong person, or built from a copy of the data rather than the live system. Before you rely on any SAP output as evidence, ask:

- Who generated the report — you, directly, or someone else who then gave it to you?
- Was it generated directly from the production environment, or from an extract, a copy, or a spreadsheet someone built from it?
- What company codes, dates, and document types were actually included — and did you confirm that, or assume it?
- Were any records excluded, and if so, was the exclusion justified and documented?
- Can the record count or totals be reconciled to an independent source?
- Is this an "information produced by the entity" (IPE) item — and if so, has its own reliability been established?
- How was the report's completeness and accuracy actually validated, not just assumed?
- Could the user who ran this report have altered the output before handing it to you?

These questions apply before most SAP execution lessons in the online course, not after. Ask them of the population before you start sampling, not once you're already partway through testing it.

### A Note on SAP Examples in This Guide and the Online Course

Several transaction examples in this guide and in the online course are correct in a typically configured environment but shouldn't be treated as universal:

- FBL3N displays G/L account line items; it is not automatically a complete journal-entry population for every testing objective.
- FB03 can display accounting documents, but an "approval status" may require workflow history, custom fields, change logs, or another application depending on configuration.
- GRC application names and navigation vary by GRC version, NWBC configuration, and Fiori deployment.
- A mitigating or compensating control recorded in GRC does not automatically prove that control is properly designed and operating effectively — you still have to test it.

**ENVIRONMENT DEPENDENCY**

Transaction codes are stable across most SAP ECC and S/4HANA releases. Fiori app IDs and exact GRC menu paths can vary by release and by how your specific client has configured their system. Always confirm the exact app ID, business role assignment, and what a report actually includes with your Security/GRC lead before your first live test on a new client — never assume every SAP environment is configured identically to the last one.

## Part 7 — The SAP Testing Execution Guide Online Course

### *Now the T-codes will mean something*

You now know Nadia, Priya, Marcus, and Théo. You know who reviews your work and who to escalate to. You know what a typical day looks like and what's expected of you in your first 30 and 90 days. What you haven't done yet is actually run the transactions.

That's what the online course is for. It's a self-paced, browser-based companion built directly from the same guide referenced throughout this manual — for every one of the 22 scope areas in the story series, it gives you the exact SAP transaction codes, Fiori app names, and GRC navigation paths a junior consultant actually uses to pull the evidence.

#### THE ACCESS LIST, IN SCREEN FORM

Book 1's "Execution Steps" in the online course — select the risk ID in GRC Access Risk Analysis, confirm the roles in PFCG, cross-check in SUIM — are the exact actions behind the story you just read. Reading the story first is what makes those steps feel like finishing something, not just following instructions.

### What the Course Covers

The course is organized into the same 6 Parts as the printed SAP Testing Execution Guide, one Book per deficiency in the story series:

- Part I — Access Control & Identity (Books 1, 4, 7, 13, 16, 17)
- Part II — IT General Controls: Change & Operations (Books 2, 5, 8, 18, 19, 20)
- Part III — Record to Report (Books 3, 6, 9)
- Part IV — SAP GRC Platform Modules (Books 14, 15)
- Part V — Governance, Disclosure & Executive Reporting (Books 10, 11, 12)
- Part VI — Legal & Compliance Adjacent Scope (Books 21, 22)

Every Book in the course gives you the same five things, together on one page: the scenario, the exact Key Transactions and Apps, step-by-step Execution Directions, the Evidence to Capture, and the Common Pitfall to watch for — the same shape as the finding Nadia's team worked through in the story you just read.

### How to Use It — Two Windows, Not One

The course is built to run alongside your own SAP session, not instead of it. Reading a Book without also opening SAP and repeating the steps yourself will teach you far less than reading it while you do.

1. Sign in to the course with the email your TIB administrator enrolled you with.

2. Start with the Course Introduction inside the app — it covers the same "before you touch a production system" rule this guide has already walked you through, plus a quick map of the 6 Parts.
3. Open your own SAP session alongside the course — SAP GUI on your desktop, or a browser tab if your access is Fiori/WebGUI-based — and place the two windows side by side.
4. Work through Book 1 first, since you already know its story. Notice how each Execution Step maps to something Nadia, Priya, or Marcus actually did on the page.
5. From there, follow your actual testing assignments — use the Deficiency Coverage table on the next page to find the Book that matches whatever scope area you've just been handed.

**ASK YOUR ADMINISTRATOR**

The exact course URL and your enrollment status are set up by your TIB administrator. If you're not sure you're enrolled, or don't have the link, ask before your first assigned test — don't wait until you need it under deadline pressure.

## Part 8 — Continuing Your Reading

*A map for the other 21 stories, read as your assignments call for them*

The Access List is the only full story in this guide — on purpose. The remaining 21 books stay in the TIB Story Library, and this part is your map for reading them: not all at once, but as your actual testing assignments bring you into each scope area.

### How the Series Fits Together

The Thornfield series follows one controls team through five fiscal years at a fictional newly public company, tracing control deficiencies across nearly every scope area a real SAP SOX/ITGC/GRC engagement touches. Three original threads — access/segregation of duties, IT change management, and record-to-report — run continuously from Year 1 through Year 3 (Books 1–9), widen into an executive-level capstone (Book 10), and open into two new domains in Years 4 and 5: SEC disclosure and cybersecurity disclosure controls (Books 11–12). Books 13–22 return to Year 1 and round out the remaining scope areas, each told as its own self-contained find-and-fix story using the same cast.

The three continuing threads reward reading in sequence (1 → 4 → 7, then 2 → 5 → 8, then 3 → 6 → 9 → 11 → 12), since each sequel depends on the reader already knowing what was built — and who built it — in the book before it. Books 13–22 can be read in any order, at any time — each stands alone, set within Year 1 alongside the original three.

### Deficiency Coverage — Your Reading Map

Use this exactly the way the online course is organized: find the deficiency that matches your current testing assignment, then read that story — and open the matching Book in the course — together.

| # | Deficiency (Book)    | Domain                 | The Business Risk                                                                               | SAP Tools (Reference)                  |
|---|----------------------|------------------------|-------------------------------------------------------------------------------------------------|----------------------------------------|
| 1 | The Access List      | Access Control / SoD   | Already read — Part 1 of this guide                                                             | GRC Access Risk Analysis, PFCG, SUIM   |
| 2 | The Emergency Change | ITGC Change Management | Six unauthorized production transports, and the process nobody had built for a bad Saturday.    | STMS, SE01/SE09/SE10                   |
| 3 | The Approval Limit   | Record to Report       | A misplaced zero in a workflow field lets six months of large journal entries slip past review. | FBL3N, FB03, SWI1/SWIA                 |
| 4 | The Next Badge       | Access Control / SoD   | Denise retires. Does the fix survive the person who inherits her badge?                         | SU01, SUIM, GRC Access Request History |
| 5 | The Cutover          | ITGC Change Management | A full system upgrade weekend puts the process through 218 changes in 72 hours.                 | STMS, SE03, SPAM/SAINT                 |

| #  | Deficiency (Book)         | Domain                        | The Business Risk                                                                                            | SAP Tools (Reference)                          |
|----|---------------------------|-------------------------------|--------------------------------------------------------------------------------------------------------------|------------------------------------------------|
| 6  | The Other Ledger          | Record to Report              | Thornfield's first acquisition brings a company with nine "clean" years and no real control behind them.     | FB03/FBL3N (or legacy equivalent)              |
| 7  | The Fourth Chair          | Access Control / SoD          | Priya moves on. Jamal has to find a genuinely new conflict — alone.                                          | GRC Access Risk Analysis (Procurement), SE16N  |
| 8  | The Third Party           | ITGC Change Management        | Cost pressure pushes transports to a vendor. Whose evidence is it now?                                       | STMS, SE01, vendor log reconciliation          |
| 9  | The Tip Line              | Record to Report              | An anonymous hotline call tests whether "write it down as you find it" holds under real pressure.            | FB03 change history, SE16N on BKPF/BSEG        |
| 10 | The Signature Page        | Executive & Board             | Three years of the same story, seen from the desk where the certification actually gets signed.              | Issue/deficiency tracker discipline            |
| 11 | The Comment Letter        | SEC Disclosure / ICFR Scope   | Nadia moves into Grace's old chair. An SEC comment letter tests two years of documentation discipline.       | Evidence file assembly (FB03/FBL3N/SE16N)      |
| 12 | The Four-Day Clock        | Disclosure Controls (SOX 302) | A contained cybersecurity incident sits unescalated for three weeks. A second-year consultant finds the gap. | SM21/SM20, STMS/SE01 cross-reference           |
| 13 | The Tile                  | SAP Fiori Security            | A launchpad tile grants access the backend role was supposed to block.                                       | /UI2/FLPD_CUST, SU24, PFCG                     |
| 14 | The Rule That Never Fired | GRC Process Control (CCM)     | An automated exception rule returns a clean result for six weeks — because it silently stopped checking.     | GRC PC business rules, SM37, SE16N             |
| 15 | The Risk Register         | GRC Risk Management           | A risk marked "mitigated" points to a control that was never real.                                           | GRC RM Risk Workbench, control cross-reference |
| 16 | The Firefighter Log       | Emergency Access Mgmt (EAM)   | Firefighter access used thirty-one times. Reviewed twice.                                                    | GRAC_SPM, Firefighter Log Report, SM20         |
| 17 | The Leaver                | Joiner-Mover-Leaver           | A terminated employee logs into SAP four days ago, five weeks after his last day.                            | SU01, SUIM (RSUSR200), SM20                    |
| 18 | The Untested Backup       | Computer Operations           | 364 clean backup reports. Zero times anyone actually restored one.                                           | DB13, DB12, live restore test                  |
| 19 | The Interface Gap         | Interface / Data Conversion   | Fourteen units exist in the warehouse system and nowhere in SAP at all.                                      | SM58, SXMB_MONI, WE02/WE05, BD87               |
| 20 | The Back Door             | Custom Code / ABAP Security   | A four-year-old shortcut transaction quietly bypasses the standard authorization check.                      | SE93, SE38/SE80, SU24, SCI                     |
| 21 | The Retention Policy      | Data Privacy (GDPR-style)     | A well-written retention policy was never connected to anything that actually enforced it.                   | SE16N (PA0002/LFA1), ILM transactions          |

| #  | Deficiency (Book)   | Domain                 | The Business Risk                                                                             | SAP Tools (Reference)    |
|----|---------------------|------------------------|-----------------------------------------------------------------------------------------------|--------------------------|
| 22 | The Indirect Access | SAP Licensing Exposure | Forty percent of sales orders touch SAP with no named user — and no license evaluation, ever. | USMM, SM59, ST03N, SE16N |

### The Recurring Cast, at a Glance

The table below covers the three continuing threads (Books 1–12). Books 13–22 reuse Nadia, Priya, Marcus, Théo, Devon, Ilse, Roberto, Grace, Yusuf, and Claire as needed, each paired with one or two new characters specific to that book’s scope area — introduced fully in each book’s own cast page, so no prior reading is required.

| Character(s)                 | Thread                            | Arc                                                        |
|------------------------------|-----------------------------------|------------------------------------------------------------|
| Nadia Brooks                 | Senior SAP SOX/ITGC Controls Lead | The throughline across all ten Year 1–3 books.             |
| Priya Nair → Jamal Reyes     | Access Control / SoD thread       | Priya owns it through Year 2; Jamal inherits it in Year 3. |
| Marcus Webb                  | ITGC Change Management thread     | Owens it start to finish, across all three years.          |
| Théo Laurent                 | Record to Report thread           | Owens it start to finish, across all three years.          |
| Grace Odum / Diane Whitfield | Compliance Director / CFO         | The executive lens — fully centered in Book 10.            |

#### IF YOU WANT FULL SCOPE COVERAGE FAST

Read Books 1–3 (the original three threads — you’ve already read Book 1), then dip into Books 13–22 in any order based on which scope area is most relevant to your own role.

#### RECOMMENDED ORDER FROM HERE

Continue with Books 4, 5, and 6 (Year 2 of the three original threads) as your comfort grows, or jump straight to whichever Book number matches your next real testing assignment using the table above. There is no wrong order — only the order your actual work calls for.

## How You'll Be Assessed

### *What "good" actually looks like, made explicit*

Transaction navigation matters, but it is not most of the job — and it shouldn't be most of how your progress gets measured. By the end of your first 90 days, you should be able to:

- explain the business risk without mentioning a transaction code;
- identify the control objective;
- determine the correct population;
- explain why the SAP report you chose is appropriate;
- validate the completeness and accuracy of that report;
- distinguish an unusual item from a confirmed exception;
- request evidence professionally;
- handle process-owner pushback without over-promising;
- recognize when escalation is required;
- write a defensible workpaper conclusion;
- propose remediation that addresses the design problem, not just the symptom;
- retest the remediation;
- explain the result to a Senior Lead in five minutes.

### How the Weight Breaks Down

This is the model your Senior Lead is likely using, even informally, when they review your work. SAP execution accuracy is real and matters — it's just the smallest single piece of what makes a workpaper defensible.

| Competency                                 | Weight |
|--------------------------------------------|--------|
| Business risk and control understanding    | 20%    |
| Testing strategy and population definition | 15%    |
| Evidence evaluation                        | 15%    |
| Consultant judgment and escalation         | 15%    |
| Workpaper and conclusion quality           | 15%    |
| Stakeholder communication                  | 10%    |
| SAP execution accuracy                     | 10%    |

**THE POINT OF THIS TABLE**

If you only ever get faster at clicking through transactions, you will plateau. The consultants who advance fastest are the ones who treat every one of these seven rows as something to deliberately get better at — not just the last one.